UAA8

Sécurité des données

Théorie & cas pratiques

Technique de transition

–

Option Informatique

–

Titulaire du cours : L. Embrechts

Table des matières

1. Introduction.....5
2. Les trois piliers fondamentaux de la sécurité des données.....6
2.1. Pourquoi ces trois piliers sont-ils indissociables ?.....6
2.2. La Confidentialité.....7
2.3. L'Intégrité.....7
2.4. La Disponibilité.....8
2.5. L'équilibre des trois piliers.....8
2.6. Exercice pratique.....8
3. Le profil utilisateur.....10
3.1. Types de profils.....10
3.1.1. Profil local.....10
3.1.2. Profil distant.....10
3.2. Création et gestion.....11
3.2.1. Profil local.....11
3.2.2. Profil distant.....11
3.3. Activités pratiques.....13
3.3.1. Profil utilisateur local.....13
3.3.2. Profil utilisateur distant.....14
4. Les droits d'accès.....15
4.1. Profil local.....15
4.2. Profil distant.....15
4.3. Activités pratiques.....17
4.3.1. Profil utilisateur local.....17
4.3.2. Profil utilisateur distant.....18
5. Le système d'authentification.....21
5.1. Les quatre facteurs d'authentification fondamentaux.....21
5.1.1. Facteur de connaissance (*ce que tu sais*).....22
5.1.2. Facteur de possession (*ce que tu détiens*).....22
5.1.3. Facteur inhérent (*ce que tu es*).....22
5.1.4. Facteur contextuel/comportemental (émergent).....23
5.2. Authentification multifacteur (2FA ou MFA).....23
5.3. Défis et perspectives d'évolution.....24
5.3.1. Défis techniques.....24
5.3.2. Défis humains.....24
5.3.3. Tendances futures.....24
5.4. Activités pratiques.....25
5.4.1. Test du mot de passe (Safeonweb).....25
5.4.2. Robustesse d'un mot de passe.....25
5.4.3. Utilisation de itsme®.....28
5.4.4. Configurer l'authentification à deux facteurs.....30
6. Le chiffrement des données.....31

6.1. Principe fondamental....31
6.2. Les deux grandes familles de chiffrement....31
6.2.1. Le chiffrement symétrique....31
6.2.2. Le chiffrement asymétrique....33
6.3. Applications pratiques du chiffrement....34
6.3.1. Chiffrement de disque....34
6.3.2. HTTPS et certificats SSL/TLS : sécuriser le web....34
6.3.3. Le « chiffrement de bout en bout »....35
6.4. Défis et limitations du chiffrement....36
6.4.1. Le défi de la gestion des clés....36
6.4.2. L'équilibre performance-sécurité....37
6.4.3. La menace quantique....37
6.5. Règles d'or du chiffrement....37
6.6. Outils recommandés....37
6.7. Activités pratiques....37
6.7.1. Vérifier le chiffrement d'un site web....37
6.7.2. Comparatif des messageries....38
6.7.3. Vulnérabilité des wifi publics....38
6.7.4. Cracker un mot de passe hashé....38
7. L'intégrité des données....41
7.1. Intégrité physique vs. logique....41
7.2. Les empreintes (hash)....41
7.2.1. Exemple pratique....42
Ici, l'ordinateur distingue rapidement La Joconde (tableau du haut) de Saint Jean-Baptiste (tableau du bas)....42
7.2.2. Calculer le hash d'un fichier sur Windows....43
7.2.3. Calculer le hash d'un fichier sur MacOS....43
7.2.4. Calculer le hash d'un fichier sur Linux....43
7.3. Signature numérique....44
7.4. Vérification d'intégrité en base de données....45
7.5. Activités pratiques....46
7.5.1. Vérifier l'intégrité d'un devoir ou d'un document personnel....46
7.5.2. Comparer deux versions d'un même fichier....46
7.5.3. Vérification de l'ISO Ubuntu....47
7.5.4. Cryptris....47
7.6. Bonnes pratiques....47
7.7. Enjeux futurs....47
8. La sauvegarde des données....48
8.1. Scénarios courants de perte de données....48
8.2. Les trois types de sauvegarde....48
8.2.1. Sauvegarde complète....48
8.2.2. Sauvegarde incrémentielle....48
8.2.3. Sauvegarde différentielle....49
8.3. La règle 3-2-1....53
8.4. Solutions de sauvegarde....53

8.4.1. Sauvegarde automatique de Windows....53
8.4.2. Solutions Cloud....53
8.5. Protection spécifique contre les ransomwares....54
8.6. Audit de sécurité personnel....54
9. Les logiciels malveillants....55
9.1. Panorama des grandes familles de malwares....55
9.2. Fonctionnement détaillé....55
9.2.1. Le virus....55
9.2.2. Le ver....55
9.2.3. Le Cheval de Troie....56
9.2.4. Le rançongiciel....56
9.2.5. Le Spyware / Keylogger....56
9.2.6. Le Rootkit....56
9.2.7. Le Botnet....56
9.3. Chaine d'infection typique....57
9.3.1. Ingénierie sociale : la ruse avant la technique....57
9.3.2. Exploitation : la faille qui laisse entrer le programme....57
9.3.3. Installation : le malware prend ses quartiers....57
9.3.4. Action : le malware remplit sa mission....58
9.3.5. Propagation ou persistance : survivre et infecter les autres....58
9.4. Signes d'une infection....58
9.5. Outils et commandes de détection....58
9.6. Bonnes pratiques....59
9.7. Activités pratiques....59
9.7.1. Test du phishing (Safeonweb)....59

1. Introduction

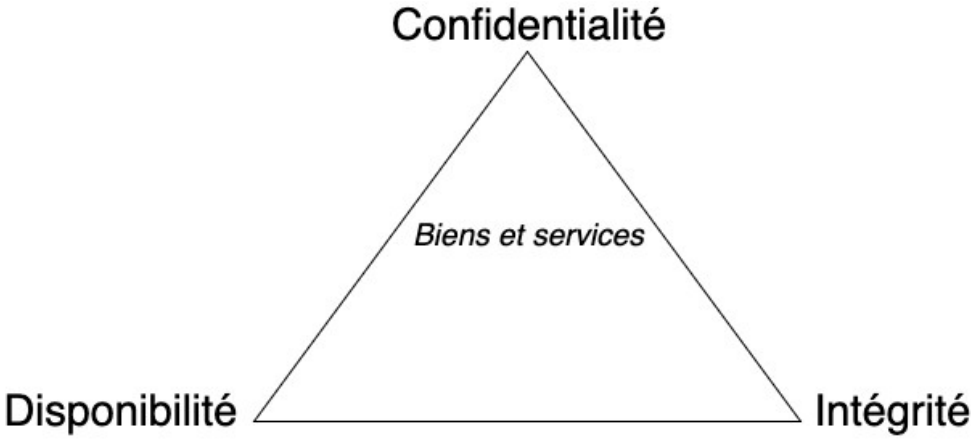
Dans notre monde de plus en plus connecté, la sécurité des données informatiques est devenue une compétence essentielle que tout utilisateur responsable doit maîtriser.

Ce cours vous guidera à travers les fondamentaux de la protection des systèmes informatiques. Vous découvrirez comment sécuriser efficacement vos données en explorant la gestion des profils utilisateurs, les mécanismes d'authentification et les stratégies de défense contre les logiciels malveillants.

À travers des exercices pratiques, vous développerez les compétences nécessaires pour protéger vos informations personnelles et professionnelles dans l'environnement numérique que vous utilisez quotidiennement.

2. Les trois piliers fondamentaux de la sécurité des données

Dans notre monde hyperconnecté où chaque personne possède un smartphone, utilise des plateformes en ligne et stocke ses travaux sur le cloud, la sécurité des données n'est plus un concept abstrait réservé aux informaticiens. C'est une réalité quotidienne qui vous concerne directement, que vous envoyiez un devoir par email, partagiez une photo sur Instagram ou accédiez à votre espace numérique de travail.



La sécurité informatique repose sur un principe fondamental appelé **la triade CID** - un acronyme qui désigne les trois piliers indissociables de la protection des données : **Confidentialité, Intégrité et Disponibilité.**

Cette triade constitue le socle de toute stratégie de sécurisation, du simple ordinateur personnel aux infrastructures les plus complexes des entreprises et administrations.

2.1. Pourquoi ces trois piliers sont-ils indissociables ?

Imaginez votre vie numérique comme une maison. La **confidentialité** serait les verrous sur vos portes, l'**intégrité** la solidité de vos murs qui ne s'effritent pas, et la **disponibilité** le fait que vous puissiez toujours entrer chez vous quand vous en avez besoin.

Retirer l'un de ces éléments rendrait votre maison vulnérable : des verrous sans murs solides, des murs solides mais pas de clés pour entrer, ou encore l'accès à une maison dont les murs s'effondrent.

Cette approche triangulaire reflète une réalité simple : **la sécurité des données n'est efficace que si elle protège simultanément ces trois aspects**.

Un système qui garantirait uniquement la confidentialité mais pas la disponibilité serait inutile en cas de panne. De même, des données toujours accessibles mais facilement altérables perdraient toute valeur.

2.2. **La Confidentialité**

La *confidentialité* garantit que seules les personnes autorisées peuvent accéder à vos informations.

Dans votre quotidien, cela se traduit par plusieurs situations concrètes :

- **Vos mots de passe** : ils protègent l'accès à vos comptes personnels, vos notes scolaires, vos conversations privées
- **Vos photos sur les réseaux sociaux** : vous contrôlez qui peut les voir grâce aux paramètres de confidentialité
- **Votre dossier scolaire numérique** : vos notes, absences et évaluations ne doivent être visibles que par vous, vos parents et l'équipe pédagogique

> *L'exemple le plus récent et le plus marquant concerne la cyberattaque de grande ampleur contre le Service Public de Wallonie (SPW) identifiée le 17 avril 2025. Selon des sources fiables, la fuite de données ciblerait des informations relatives aux exportations d'armes et d'autres données sensibles. L'attaque a mobilisé 10 000 ordinateurs, des milliers de serveurs et plus de 800 applications, nécessitant l'intervention d'une centaine de personnes. Les autorités ont pris la décision drastique de couper l'ensemble des connexions internet pour limiter les fuites potentielles.*[1]

2.3. **L'Intégrité**

L'*intégrité* assure que vos données restent exactes, complètes et non modifiées sans autorisation.

Ce principe est crucial pour maintenir la confiance dans l'information numérique.

Dans votre quotidien, cela se traduit par plusieurs situations concrètes :

- **Vos devoirs et projets** : s'assurer qu'ils n'ont pas été corrompus ou modifiés entre la sauvegarde et la remise
- **Les informations que vous consultez** : vérifier l'authenticité des sources et détecter les "fake news"
- **Vos évaluations** : protéger vos notes contre toute falsification, accidentelle ou malveillante

Les exemples de compromission de l'intégrité sont nombreux : modification malveillante de notes dans une base de données scolaire, altération de fichiers par des virus, ou encore manipulation d'informations lors de leur transmission sur Internet.

1 Source : https://fr.wikipedia.org/wiki/Cyberattaque_contre_le_Service_Public_de_Wallonie_(2025)

2.4. La Disponibilité

La *disponibilité* garantit que les systèmes et données fonctionnent quand vous en avez besoin, avec un niveau de performance acceptable.

Sans disponibilité, même les données les mieux protégées deviennent inutiles.

Dans votre quotidien, cela se traduit par plusieurs situations concrètes :

- **Vos cours en ligne** : pouvoir accéder à vos ressources pédagogiques 24h/24, même en période d'examens
- **Vos sauvegardes** : récupérer vos fichiers même si votre ordinateur tombe en panne
- **Les services scolaires** : consulter vos notes, ou rendre un devoir sans interruption technique

Les attaques par déni de service (DDoS) et les ransomwares constituent les principales menaces contre la disponibilité. Ces derniers chiffrent vos fichiers et exigent une rançon pour les libérer.

> *En 2022, l'Université de Liège et le CHU de Liège ont résisté à une attaque informatique qui a duré 27 heures . L'attaque a saturé les serveurs avec un pic de 70.000 connexions par seconde, impactant notamment les étudiants qui ne pouvaient plus consulter leurs cours en ligne ou accéder au système de mails.*[2]

2.5. L'équilibre des trois piliers

Dans la pratique, ces trois piliers doivent être équilibrés selon le contexte d'usage.

Par exemple, un service de streaming vidéo privilégiera la disponibilité (pour éviter les coupures) tout en maintenant un niveau suffisant de confidentialité et d'intégrité. À l'inverse, un système bancaire mettra l'accent sur la confidentialité et l'intégrité, quitte à accepter des temps d'accès plus longs.

Pour vous, cette approche équilibrée se traduit par des choix quotidiens : utiliser des mots de passe forts (confidentialité), vérifier vos sources d'information (intégrité), et maintenir des sauvegardes de vos travaux (disponibilité).

Cette compréhension des trois piliers vous donne les clés pour évaluer la sécurité de n'importe quel système numérique que vous utilisez et adopter les bons réflexes de protection. C'est sur cette base solide que nous allons maintenant explorer les techniques concrètes pour implémenter ces principes dans votre environnement numérique quotidien.

2.6. Exercice pratique

À partir de la liste de services, replace chaque service sur ou autour du triangle, selon le ou

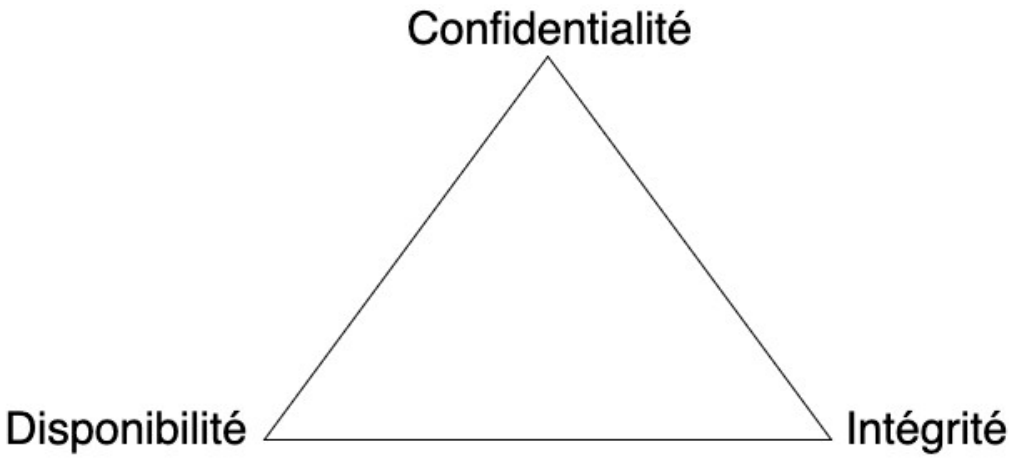
2 Source : https://www.rtbf.be/article/une-attaque-informatique-contre-l-universite-et-le-chu-de-liege-pendant-26-heures-la-situation-est-redevenue-normale-10999459

les piliers de sécurité qui sont les plus importants pour lui.

Voici les services à analyser (à replacer sur le schéma) :

1. Service de streaming audio
2. Messagerie instannée
3. Dossier médical en ligne
4. Une plateforme d'apprentissage en ligne
5. Application bancaire en ligne
6. Système d'alarme incendie connecté
7. Réseau social
8. Plateforme dédiée aux lanceurs d'alerte
9. Système de vote électronique
10. Plateforme e-commerce

Justifie tes choix !



3. Le profil utilisateur

Un *profil utilisateur* regroupe ton nom de connexion, ton mot de passe, tes réglages et les ressources auxquelles tu as droit.

C'est ton identité numérique qui détermine ce que tu peux voir, modifier ou exécuter sur un système informatique. Cette identité peut être stockée soit localement sur une machine, soit à distance sur un serveur, chaque approche ayant ses avantages et ses limites.

3.1. Types de profils

3.1.1. Profil local

Un profil local est créé automatiquement lors de ta première connexion sur un poste donné. Il est enregistré dans le disque dur de la machine (Windows : `C:\Users\<nom>`, Linux : `/home/<nom>`, macOS : `/Users/<nom>`). Il ne quitte jamais l'ordinateur où il a été généré : si tu te connectes sur un autre poste, un nouveau profil local y sera créé.

Caractéristiques principales :

- **Isolation** : Chaque compte dispose de son propre espace. Tes modifications n'affectent ni les autres comptes ni le système global.
- **Performance** : Comme tout est stocké localement, l'ouverture de session est rapide ; aucun transfert réseau n'est requis.

3.1.2. Profil distant

À l'opposé, les profils distants sont stockés sur un serveur central et récupérés à chaque connexion. Cette approche transforme radicalement la gestion des utilisateurs et ouvre la voie aux systèmes de droits d'accès sophistiqués.

Caractéristiques principales :

- **Portabilité** : Le profil distant est accessible depuis n'importe quel poste connecté au réseau ou à Internet. Tes réglages, fichiers et préférences te suivent partout, que tu sois à l'école, à la maison ou sur un autre ordinateur du réseau.
- **Centralisation** : Toutes les données du profil (identifiants, droits d'accès, paramètres, fichiers personnels) sont stockées sur un serveur ou dans une base de données centralisée. Cela facilite la gestion par les administrateurs : création, modification, suppression ou récupération d'un profil peuvent se faire à distance et de manière uniforme.
- **Synchronisation** : À chaque connexion, ton environnement personnel est téléchargé ou synchronisé depuis le serveur. Tes modifications sont ensuite enregistrées sur le serveur à la fermeture de session ou en temps réel selon la configuration.
- **Sécurité** : Le stockage centralisé permet d'appliquer des politiques de sécurité

strictes (sauvegardes automatiques, contrôle d'accès, surveillance des connexions). En cas de perte ou de vol d'un ordinateur, tes données restent protégées sur le serveur.

3.2. Création et gestion

3.2.1. Profil local

Sous Linux, la commande `useradd` crée un compte et place son enregistrement dans `/etc/passwd`.

```
sudo useradd -m -s /bin/bash eleve1      # crée le profil
sudo passwd eleve1                       # définit le mot de passe
sudo usermod -aG groupe-projets eleve1   # ajoute au groupe
```

Sous Windows, l'outil « Comptes d'utilisateurs » ou `net user` joue le même rôle.

```
net user eleve1 motdepasse /add           # crée l'utilisateur eleve1
net localgroup Utilisateurs eleve1 /add   # ajoute au groupe Utilisateurs
```

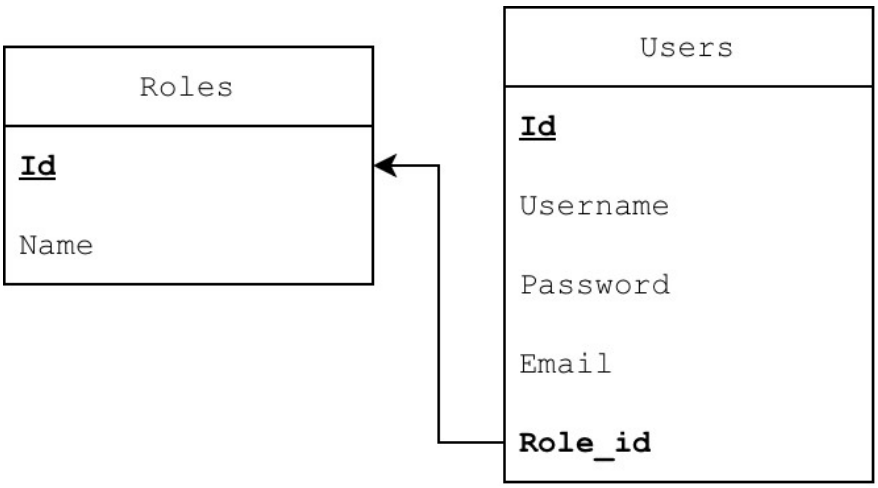
Pour chaque nouveau profil, pense à :

- ✔ Choisir un nom clair.
- ✔ Fixer un mot de passe initial fort puis exiger son changement à la première connexion.
- ✔ Attribuer le groupe correct pour profiter des droits partagés (voir section suivante).

3.2.2. Profil distant

Un profil distant repose sur une base de données centralisée qui stocke toutes tes informations : identifiants, mots de passe, préférences, historique de connexion et surtout rôles et permissions. Contrairement au profil local figé sur une machine, le profil distant t'accompagne partout où tu te connectes.

Cette base de donnée possède généralement une table `Users`, une table `Roles`, et une table `Permissions` (détaillée au point suivant).




```sql
-- Table des rôles
CREATE TABLE roles (
    id INT PRIMARY KEY,
    name VARCHAR(50) UNIQUE NOT NULL
);
-- Table des utilisateurs
CREATE TABLE users (
    id INT PRIMARY KEY,
    username VARCHAR(50) UNIQUE NOT NULL,
    password VARCHAR(255) NOT NULL,
    email VARCHAR(100) NOT NULL,
    role_id INT NOT NULL,
    FOREIGN KEY (role_id) REFERENCES roles(id)
);
```

Ensuite, les profils ainsi que les utilisateurs sont créés :

```sql
INSERT INTO roles (id,name) VALUES (1,'eleve');
INSERT INTO roles (id,name) VALUES (2,'enseignant');
INSERT INTO roles (id,name) VALUES (3,'administrateur');
INSERT INTO roles (id,name) VALUES (4,'parent');
-- Utilisateur eleve1 est un élève
INSERT INTO users (id,username, password, email, role_id)
VALUES (1,'eleve1', 'HASHED_PASSWORD', 'eleve1@exemple.fr', 1);
-- Utilisateur prof1 est un enseignant
INSERT INTO users (id,username, password, email, role_id)
VALUES (2,'prof1', 'HASHED_PASSWORD', 'prof1@exemple.fr', 2);
-- Utilisateur admin1 est un administrateur
INSERT INTO users (id,username, password, email, role_id)
VALUES (3,'admin1', 'HASHED_PASSWORD', 'admin1@exemple.fr', 3);
```

3.3. **Activités pratiques**

3.3.1. **Profil utilisateur local**

L'objectif de cette activité est de découvrir le fonctionnement et l'isolation des profils locaux sur un ordinateur en partageant une machine entre plusieurs utilisateurs.

Connexion au poste à partir d'un nouveau compte

1. Sur l'écran d'accueil, clique sur "Ajouter un utilisateur" ou demande à l'enseignant de créer un nouveau compte local (voir commandes fournies dans le cours).
2. Connecte-toi avec ce compte pour la première fois.

Personnalisation de l'espace

3. Change le fond d'écran, crée un document texte sur le Bureau, modifie la disposition du menu Démarrer ou crée de nouveaux raccourcis.
4. Ouvre un navigateur web, sauvegarde un favori, et ferme la session.

Isolation des données

5. Déconnecte-toi et connecte-toi avec un autre compte (« eleve2 »).
6. Vérifie que rien n'a changé : le fond d'écran, le Bureau, les favoris du navigateur sont différents ou vierges.
7. Tente d'accéder au dossier Documents ou Bureau de l'autre utilisateur : constate que cela est impossible sans droits administrateur.

Qu'as-tu observé concernant la séparation des réglages et des données ?

Quels problèmes pourrais-tu avoir si tu travaillais toujours sur un compte partagé ?

3.3.2. **Profil utilisateur distant**

L'objectif de cette activité est de mettre en place une base de données relationnelle permettant la gestion centralisée de profils utilisateurs distants dans un contexte professionnel ou commercial (tel qu'une boutique en ligne ou une plateforme d'entreprise), puis d'utiliser des requêtes SQL pour extraire des informations précises sur ces utilisateurs et leurs droits.

Création de la base de données

1. Rends-toi sur l'outil en ligne « DB Disco » : https://pic.crzt.fr/dbdisco/
2. À l'aide d'une requête SQL de DDL, crée une base de données contenant une table « Utilisateurs » et une table « Rôles » en respectant la structure vue précédemment.

Création des rôles et des utilisateurs

3. Ajoute les rôles suivants : client, analyste, gestionnaire et administrateur.
4. Ajoute les utilisateurs suivants : Marc (client), Julie (gestionnaire), Mathieu (administrateur), Noémie (analyste), Jérôme (analyste), Thierry (gestionnaire) et Léna (client).

Extraction des informations

5. Liste tous les utilisateurs ainsi que leur rôle associé
6. Affiche le rôle de Julie
7. Affiche le pseudo de tous les analystes

4. Les droits d'accès

Les *droits d'accès* déterminent qui peut consulter, modifier ou exécuter des fichiers, dossiers ou fonctionnalités d'un système informatique.

Dans le domaine de la sécurité des données, les autorisations sont la première barrière contre la fuite de données.

4.1. Profil local

Sur un ordinateur autonome ou en réseau local, chaque utilisateur possède un profil enregistré sur la machine. Les droits d'accès sont gérés par le système d'exploitation (Windows, Linux, macOS) et s'appliquent directement aux fichiers et dossiers du disque.

Principaux droits :

- **Lecture (r)** : ouvrir ou consulter un fichier/dossier.
- **Écriture (w)** : modifier, ajouter ou supprimer un fichier/dossier.
- **Exécution (x)** : lancer un programme ou un script.

Sur Windows, la démarche est la suivante :

- Clic droit sur le fichier ou dossier → Propriétés.
- Onglet Sécurité : liste les utilisateurs et groupes ayant des droits.
- Cliquer sur Modifier pour ajouter, retirer ou ajuster les autorisations :
  - Lecture
  - Écriture
  - Modification
  - Contrôle total
- Pour des réglages avancés (héritage, permissions spéciales), cliquer sur Avancé.
- Pour attribuer un nouveau propriétaire, utiliser le bouton Modifier dans la section Propriétaire.

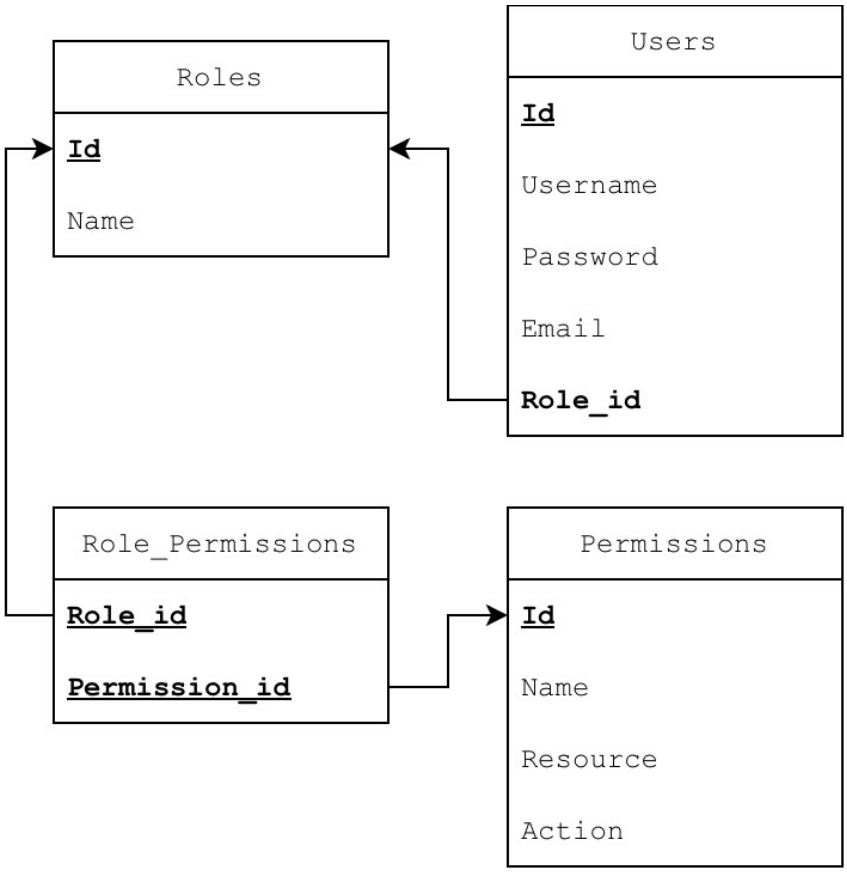
4.2. Profil distant

Les plateformes web modernes implémentent un système hiérarchique de rôles où chaque utilisateur se voit attribuer des permissions spécifiques.

Par exemple, sur une plateforme éducative :

- **Administrateur** : accès total aux fonctionnalités, installation d'extensions, gestion des utilisateurs
- **Enseignant** : création et modification de contenus, évaluation, suivi des élèves

- **Élève** : consultation des ressources, participation aux activités, remise de devoirs
- **Parent** : consultation des notes, absences, communication avec l'équipe pédagogique



Les droits d'accès sont généralement stockés dans la table `Permissions`. Chaque permission associe un nom lisible, une ressource (ex : devoir, utilisateur, cours) et une action (ex : create, read, update, delete) pour permettre une gestion fine des droits dans l'application.

```sql
-- Table des permissions
CREATE TABLE permissions (
    id INT PRIMARY KEY,
    name VARCHAR(50),
    resource VARCHAR(50),
    action VARCHAR(50)
);


-- Insertion de permissions typiques pour une plateforme éducative
INSERT INTO permissions (id, name, resource, action)
VALUES
  (1,'Voir les devoirs', 'devoir', 'read'),
  (2,'Remettre un devoir', 'devoir', 'create'),
  (3,'Corriger un devoir', 'devoir', 'update'),
  (4,'Modifier un utilisateur', 'user', 'update'),
  (5,'Supprimer un utilisateur', 'user', 'delete'),
  (6,'Créer un cours', 'cours', 'create'),
  (7,'Modifier un cours', 'cours', 'update'),
```

```
  (8,'Supprimer un cours', 'cours', 'delete');
```

Ensuite, on attribue à chaque rôle un ensemble de permissions :

```sql
-- Table de liaison rôle-permission
CREATE TABLE role_permissions (
    role_id INT,
    permission_id INT,
    PRIMARY KEY (role_id, permission_id),
    FOREIGN KEY (role_id) REFERENCES roles(id),
    FOREIGN KEY (permission_id) REFERENCES permissions(id)
);

-- L'élève peut voir et remettre un devoir
INSERT INTO role_permissions (role_id, permission_id) VALUES
  (1, 1), -- élève, voir les devoirs
  (1, 2); -- élève, remettre un devoir

-- L'enseignant peut voir, corriger les devoirs et créer des cours
INSERT INTO role_permissions (role_id, permission_id) VALUES
  (2, 1), -- enseignant, voir les devoirs
  (2, 3), -- enseignant, corriger un devoir
  (2, 6); -- enseignant, créer un cours

-- L'administrateur a tous les droits
INSERT INTO role_permissions (role_id, permission_id) VALUES
  (3, 1), (3, 2), (3, 3), (3, 4), (3, 5), (3, 6), (3, 7), (3, 8);
```

4.3. Activités pratiques

4.3.1. Profil utilisateur local

Pour chaque situation, coche le droit le plus pertinent (un seul choix) et justifie en 1–2 phrases.

Situation	(r / w / x)	Justification
Tu veux ouvrir un PDF « Consignes_devoir.pdf » dans un dossier partagé.		
Tu dois modifier ton fichier « rapport.docx » puis l'enregistrer.		
Un dossier « Devoirs_à_rendre » sert uniquement à déposer ton fichier final (tu ne dois pas voir ceux des autres).		
Tu es autorisé à lancer un programme « Calculatrice » installé sur l'ordinateur.		

Situation	(r / w / x)	Justification
Un fichier « script_sauvegarde.sh » doit pouvoir être lancé par l'administrateur.		
Un dossier « Photos_de_classe » est consultable par tous, mais personne ne doit ajouter/supprimer.		
Un fichier « notes.csv » doit être corrigé par l'enseignant, mais pas par les élèves.		
Un dossier « Logiciels » contient des installateurs : les élèves peuvent lancer des applications déjà installées, mais ne doivent pas ajouter de nouveaux programmes.		
Tu dois seulement lire un fichier de configuration (sans le modifier) pour vérifier un paramètre.		
Un dossier « Partage_Classe » sert à déposer des fichiers pour un projet commun (plusieurs élèves ajoutent).		
Un fichier « presentation.pptx » doit être consulté pendant un exposé, sans modification.		
Un dossier « Rendus_Exam » contient des travaux : l'élève peut déposer, mais ne peut pas supprimer ni modifier après dépôt.		

4.3.2. **Profil utilisateur distant**

Poursuivons le travail initié sur DB Disco en ajoutant la notion de permissions dans votre base de données, pour mieux comprendre la gestion fine des droits d'accès dans un système professionnel.

Création de la base de données

1. Rends-toi sur l'outil en ligne « DB Disco » : https://pic.crzt.fr/dbdisco/
2. Reprends la base de données définie précédemment
3. Ajoute une table « Permissions » en respectant la structure vue précédemment

Création des permissions et attribution aux rôles

4. Ajoute les permissions suivantes : lister le catalogue, passer une commande, modifier une commande, accéder au reporting, supprimer un produit, ajouter un produit
5. Associe les permissions aux rôles :
    - client : lister le catalogue et passer une commande
    - gestionnaire : lister le catalogue, passer une commande, supprimer un produit et ajouter un produit
    - analyste : accéder au reporting
    - administrateur : toutes les permissions

Extraction des informations

6. Liste tous les rôles et, pour chacun, affiche les permissions associées (nom du rôle, nom de la permission, ressource, action).
7. Pour chaque utilisateur, affiche son rôle et toutes les permissions dont il bénéficie.
8. Affiche la liste des utilisateurs ayant le droit « Accéder au reporting ».

Quels sont les avantages et les inconvénients de centraliser les permissions au niveau des rôles plutôt qu'au niveau des utilisateurs ?

Avantages	*Inconvénients*

5. Le système d’authentification

Un *système d'authentification* est un dispositif ou un ensemble de procédures permettant à un système informatique de vérifier l'identité d’un utilisateur, d’un appareil ou d’un autre système avant de lui accorder l’accès à des ressources protégées.

La simple paire identifiant/mot de passe ne suffit plus face aux attaques modernes. Les cybercriminels disposent aujourd'hui d'outils sophistiqués : attaques par force brute automatisées, phishing ciblé, vol de données massif et ingénierie sociale. Ces menaces réelles justifient l'adoption de systèmes d'authentification plus robustes et adaptés aux enjeux contemporains.

5.1. Les quatre facteurs d’authentification fondamentaux

L'authentification moderne repose sur quatre catégories de facteurs qui peuvent être combinés pour renforcer la sécurité.

5.1.1. **Facteur de connaissance (*ce que tu sais*)**

- Mots de passe et codes PIN : information secrète mémorisée par l'utilisateur
- Questions de sécurité : réponses personnelles à des questions prédéfinies
- Phrases de passe : séquences de mots plus longues et mémorisables

Avantages	*Inconvénients*

5.1.2. **Facteur de possession (*ce que tu détiens*)**

- Téléphone mobile : réception de codes par SMS ou applications dédiées
- Tokens physiques : générateurs de codes à usage unique (OTP)
- Cartes à puce : certificats numériques stockés sur support physique
- Clés de sécurité USB : dispositifs FIDO2 compatibles

Avantages	*Inconvénients*

5.1.3. **Facteur inhérent (*ce que tu es*)**

- Empreintes digitales : reconnaissance des motifs papillaires uniques
- Reconnaissance faciale : analyse des traits du visage en 2D ou 3D
- Reconnaissance vocale : identification par les caractéristiques de la voix
- Scan de l'iris : lecture des motifs de l'iris de l'œil

Avantages	*Inconvénients*

5.1.4. **Facteur contextuel/comportemental (émergent)**

- Géolocalisation : vérification de la position géographique habituelle.
- Dynamique de frappe : analyse du rythme et de la cadence de saisie au clavier.
- Comportement de navigation : patterns de déplacement de souris et d'interaction.
- Horaires d'accès : plages temporelles habituelles de connexion.

Avantages	*Inconvénients*

5.2. **Authentification multifacteur (2FA ou MFA)**

L'authentification à deux facteurs (2FA) exige exactement deux preuves d'identité provenant de catégories différentes. L'authentification multifacteur (MFA) utilise au minimum deux facteurs mais peut en combiner davantage selon le niveau de sécurité requis.

Complète le tableau suivant en te basant sur les services (réseaux sociaux etc.) que tu utilises ou que tu connais.

Type	Action	Méthodes
1FA		
2FA		
3FA		
4FA		

5.3. **Défis et perspectives d'évolution**

5.3.1. Défis techniques

- Interopérabilité : Difficultés d'intégration entre systèmes hétérogènes
- Performance : Impact sur la vitesse de connexion, particulièrement en mobilité
- Fiabilité : Taux d'échec des systèmes biométriques selon les conditions d'usage

5.3.2. Défis humains

- Résistance au changement : Réticence des utilisateurs face aux nouvelles méthodes
- Fracture numérique : Inégalités d'accès aux technologies modernes
- Équilibre vie privée-sécurité : Tensions entre protection des données et efficacité sécuritaire

5.3.3. Tendances futures

L'authentification évolue vers plus d'intelligence et de transparence:

- Authentification continue : Surveillance comportementale permanente et discrète
- Intelligence artificielle : détection d'anomalies et adaptation automatique des politiques
- Biométrie comportementale : analyse des patterns de marche, de frappe, de navigation
- Authentification quantique : protection contre les futures menaces cryptographiques

5.4. Activités pratiques

5.4.1. Test du mot de passe (Safeonweb)

Rends-toi sur https://safeonweb.be/fr/test-du-mot-de-passe ou scanne le QR Code suivant :

Réalise le test !

5.4.2. Robustesse d'un mot de passe

> *La robustesse d'un mot de passe, c'est sa capacité à résister aux tentatives pour le deviner ou le casser. Plus un mot de passe est robuste, plus il est difficile pour quelqu'un d'autre de le trouver, même avec de nombreux essais ou des outils automatiques.*

Voici une liste de mots de passe :

1) `123456`
2) `password`
3) `chocolat2025`
4) `A1b!C3d#`
5) `qwertyuiop`
6) `M0nLycEe2025!`
7) `Juillet24_2025`
8) `X7&f$9@2Bd`
9) `azerty123`
10) `Tr0pF0rt!`

Dans un premier temps, classe ces mots de passe du moins robuste au plus robuste (*selon toi !*).

Ensuite, rends-toi sur https://www.security.org/how-secure-is-my-password/ et complète le tableau à la page suivante en utilisant l'outil proposé.

Mot de passe	*Temps nécessaire pour le trouver (robustesse)*
`123456`	
`password`	
`chocolat2025`	
`A1b!C3d#`	
`qwertyuiop`	
`M0nLycEe2025!`	
`Juillet24_2025`	
`X7&f$9@2Bd`	
`azerty123`	
`Tr0pF0rt!`	

Quel est le mot de passe le moins robuste et le plus robuste ?

Quels sont les 5 critères qui permettent d'évaluer la robustesse d'un mot de passe ?

LES MOTS DE PASSE N'ONT PLUS DE SECRET POUR VOUS !

****

UN MOT DE PASSE EN BÉTON |

Un bon mot de passe doit contenir 12 caractères, d'au moins 4 types différents : des minuscules, des majuscules, des chiffres et des caractères spéciaux. Il peut être plus court si votre compte est équipé de sécurités complémentaires !

****

IL NE DIT RIEN SUR VOUS |

Personne ne doit deviner votre mot de passe à partir du nom de votre chien ou de votre film préféré. Idem pour le code de votre smartphone : préférez un nombre aléatoire à une année.

****

UN COMPTE, UN MOT DE PASSE |

Pour éviter les piratages en cascade, chacun de vos comptes en ligne qui présente un caractère sensible (banque, messagerie, réseau social, etc.) doit être verrouillé avec un mot de passe propre et unique.

****

NE JAMAIS L'ABANDONNER EN PLEINE NATURE |

Les post-it, les fichiers texte, votre smartphone ou votre boite de messagerie ne sont pas conçus pour sécuriser le stockage de vos mots de passe. Pensez aussi à ne jamais les enregistrer dans le navigateur d'un ordinateur partagé.

****

DEUX CADENAS VALENT MIEUX QU'UN |

Quand le service vous le propose, activez la double authentification. Si quelqu'un se connecte à votre compte depuis un terminal inconnu, le site vous prévient par SMS/e-mail. Libre à vous d'autoriser ou de refuser l'accès !

****

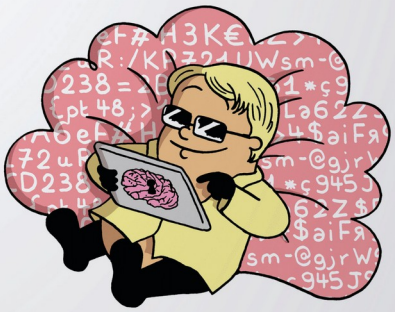
LES RETENIR SANS LES ÉCRIRE

... EN TRAVAILLANT VOS NEURONES |

Mémorisez une phrase puis utilisez la première lettre de chaque mot pour créer votre mot de passe. La phrase doit contenir des chiffres et des caractères spéciaux !

... EN REPOSANT VOS MÉNINGES |

Utilisez un gestionnaire de mots de passe ou un trousseau d'accès chiffré pour stocker vos mots de passe en toute sécurité. Vous n'aurez à retenir qu'un mot de passe pour accéder à l'ensemble de vos comptes !



****

PLUS DE CONSEILS SUR WWW.CNIL.FR

CNIL.
COMMISSION NATIONALE INFORMATIQUE & LIBERTÉS

Illustrations : Martin Vidberg

5.4.3. **Utilisation de itsme®**

Dans un premier temps, lis l'article suivant pour découvrir itsme®:
https://www.test-achats.be/hightech/internet/dossier/tout-savoir-sur-itsme

Ensuite, réponds aux questions suivantes :

- Qu'est-ce que l'application itsme® et à quoi sert-elle principalement ?

- Quels services peuvent être utilisés avec itsme® ?

- Quelles sont les quatre opérations que l'on peut faire avec itsme® ?

- Quelles sont les deux méthodes pour créer ou activer un compte itsme® ?

- Quel est le risque principal lorsqu'on utilise itsme® ?

Lisa, 17 ans, veut consulter son solde d'heures sur Student@work pour rester dans la limite de ses droits d'étudiante jobiste. Mais elle n'a encore jamais configuré itsme®, l'application officielle d'identification numérique en Belgique, qui facilite l'accès à de nombreux services publics en ligne, notamment Student@work.

Consulte sur le site officiel de itsme® pour comprendre comment créer / activer un compte https://www.itsme-id.com/fr-BE/get-started

Ensuite, réponds aux questions de Lisa pour l'aider à configurer et utiliser correctement itsme® :

Qu'est-ce qu'itsme® et à quoi ça sert ?

Ai-je besoin de matériel particulier ou d'un document spécifique pour activer itsme® ?

Quelle est la manière la plus simple d'activer un compte sur itsme® ?

5.4.4. **Configurer l'authentification à deux facteurs**

Rends-toi sur le cette page internet de Safeonweb.be

Configure l'authentification à deux facteurs sur un de tes comptes.

6. Le chiffrement des données

Le *chiffrement* est un procédé cryptographique qui consiste à transformer des données lisibles (appelées *texte en clair*) en un format codé ou illisible (appelé *texte chiffré*), de façon à ce que seules les personnes disposant de la clé de déchiffrement appropriée puissent retrouver le contenu d'origine.

Cette technique millénaire, autrefois réservée aux services secrets, est aujourd'hui omniprésente dans notre quotidien numérique. Chaque fois que tu te connectes à ton compte bancaire, que tu envoies un message sur WhatsApp ou que tu visites un site web sécurisé, le chiffrement protège tes données en les rendant illisibles pour toute personne qui tenterait de les intercepter.

6.1. Principe fondamental

Le chiffrement repose sur un processus mathématique qui transforme des informations lisibles (texte clair) en un format codé (texte chiffré) incompréhensible sans la clé appropriée.

Cette transformation est une opération cryptographique robuste qui garantit que même si un attaquant intercepte tes données, il ne pourra pas les lire sans posséder la clé de déchiffrement.

Le chiffrement répond à trois besoins de sécurité essentiels :

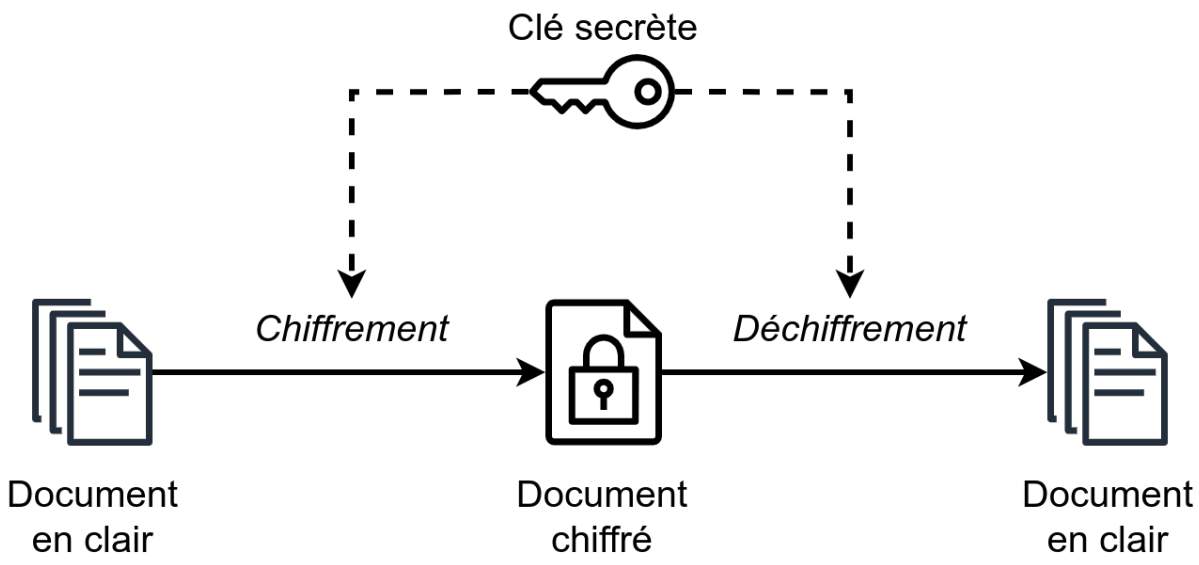
- Confidentialité : seules les personnes autorisées peuvent lire les données
- Intégrité : garantir que les données n'ont pas été modifiées pendant leur transmission ou stockage
- Authentification : vérifier l'identité de l'expéditeur d'un message

6.2. Les deux grandes familles de chiffrement

La cryptographie moderne se divise en deux approches fondamentales qui diffèrent par leur gestion des clés : le chiffrement symétrique et le chiffrement asymétrique.

6.2.1. Le chiffrement symétrique

Le chiffrement symétrique utilise une seule clé pour chiffrer et déchiffrer les données. Cette clé doit être partagée entre l'expéditeur et le destinataire avant que la communication sécurisée puisse commencer.



Le chiffrement symétrique (source : Wikipedia)

Fonctionnement :

1. Génération : Une clé secrète est créée (par exemple, une séquence de 256 bits aléatoires)
2. Chiffrement : L'expéditeur utilise cette clé pour transformer le message en texte chiffré
3. Transmission : Le message chiffré est envoyé via un canal non sécurisé
4. Déchiffrement : Le destinataire utilise la même clé pour retrouver le message original

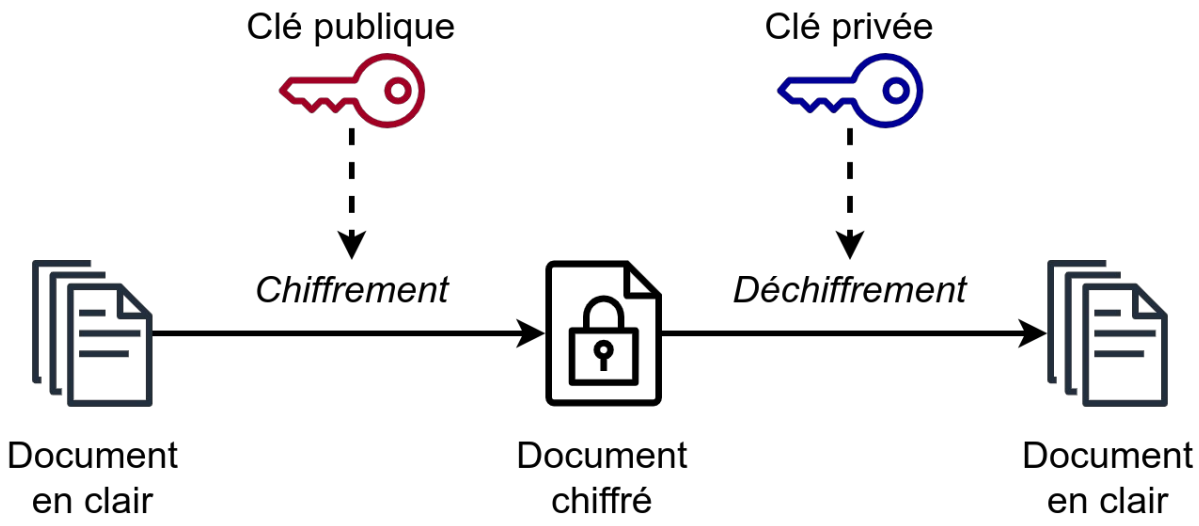
> *L'algorithme le plus connu utilisant cette méthode est l'AES (Advanced Encryption Standard).*

Avantages	Inconvénients
Rapidité : Processus de chiffrement très rapide	**Distribution des clés** : Comment partager la clé de façon sécurisée ?
Efficacité : Consomme peu de ressources système	**Multiplication des clés** : Il faut une clé unique par correspondant
Taille réduite : Le texte chiffré est de taille similaire au texte original	**Risque de compromission** : Si la clé est volée, toutes les données sont vulnérables

6.2.2. **Le chiffrement asymétrique**

Le chiffrement asymétrique utilise une paire de clés mathématiquement liées : une clé publique pour chiffrer et une clé privée pour déchiffrer.

Cette innovation révolutionnaire résout le problème de distribution des clés du chiffrement symétrique.



Le chiffrement asymétrique (source : Wikipedia)

Fonctionnement :

1. Génération : création simultanée d'une clé publique et d'une clé privée
2. Publication : la clé publique est librement distribuée, la clé privée reste secrète
3. Chiffrement : n'importe qui peut chiffrer un message avec ta clé publique
4. Déchiffrement : seul toi peux déchiffrer avec ta clé privée correspondante

> *L'algorithme le plus connu utilisant cette méthode est le RSA (Rivest-Shamir-Adleman).*

Avantages	Inconvénients
Pas de partage de secret : Aucune clé secrète à transmettre	**Lenteur** : 100 à 1000 fois plus lent que le symétrique
Authentification : Possibilité de signer numériquement	**Consommation** : Besoins importants en puissance de calcul
Échelonnage : Un seul couple de clés pour tous les correspondants	**Taille** : Texte chiffré plus volumineux que l'original

6.3. Applications pratiques du chiffrement

6.3.1. Chiffrement de disque

Le chiffrement de disque protège toutes tes données stockées localement en rendant le disque illisible sans le bon mot de passe ou la bonne clé.

Windows : *BitLocker*

Linux : *LUKS (Linux Unified Key Setup)*

macOS : *FileVault*

6.3.2. HTTPS et certificats SSL/TLS : sécuriser le web

Un *certificat de sécurité* (souvent appelé certificat SSL ou TLS) est un fichier électronique qui associe une clé cryptographique à l'identité d'un site web ou d'une organisation.

Le protocole HTTPS (HTTP Secure) utilise les certificats SSL/TLS pour chiffrer les communications entre ton navigateur et les serveurs web. Cette technologie protège tes données pendant leur transit sur Internet.

Un certificat SSL/TLS consiste en une paire de clés constituée d'une clé publique et d'une clé privée.

Son rôle est simple (le triple A) :

- ✔ **Authentifier** : Prouver que tu es bien sur le vrai site (ex: le vrai site de ta banque et non une copie pirate).
- ✔ **Anonymiser** (Chiffrer) : Rendre tes messages illisibles pour les pirates qui "écoutent" sur le réseau.
- ✔ **Assurer l'intégrité** : Garantir que personne n'a modifié ta commande ou ton message pendant le trajet.

Quand tu vois le petit cadenas dans ta barre d'adresse, voici ce qui vient de se passer en une fraction de seconde[3] :

1. Le "Bonjour" : Ton navigateur demande au site : « Hé, je veux me connecter, qui es-tu ? ».
2. La preuve d'identité : Le serveur répond : « Voici mon passeport (le certificat) avec ma clé publique ».
3. La vérification : Ton navigateur vérifie si ce passeport est un vrai (est-ce qu'il a été tamponné par une autorité de confiance ?).
4. Le code secret : Ton navigateur génère ensuite une clé de chiffrement symétrique (clé de session), qu'il chiffre à l'aide de la clé publique contenue dans le certificat du serveur puis transmet cette clé de session au serveur.
5. Tunnel privé : Seul le serveur peut déchiffrer la clé de session avec sa clé privée. Désormais, vous utilisez tous les deux ce code secret pour chiffrer toute la conversation.

En résumé, le certificat de sécurité est un élément fondamental du chiffrement sur Internet : il protège la confidentialité, l'authenticité et l'intégrité des échanges entre les utilisateurs et les sites web.

6.3.3. **Le « chiffrement de bout en bout »**

Le chiffrement de bout en bout (E2EE) est un système de communication sécurisé où seuls l'expéditeur et le destinataire final possèdent les clés nécessaires pour lire les messages.

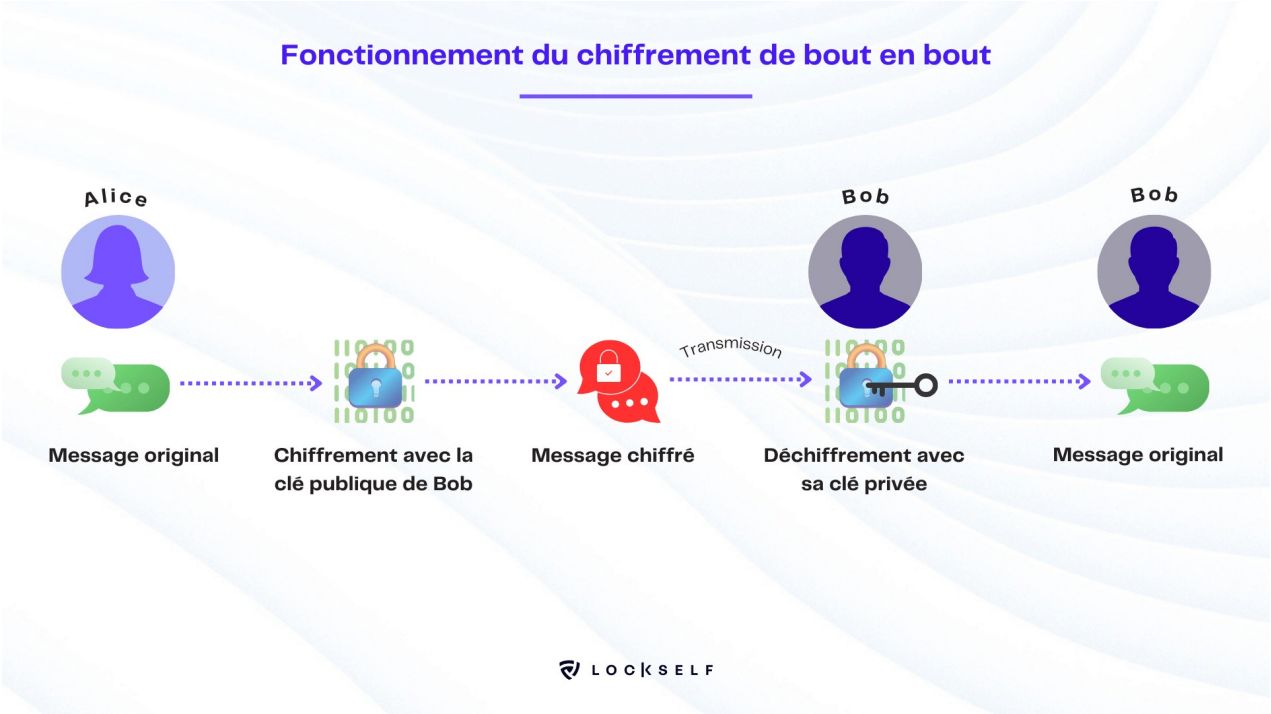
Les données sont verrouillées avant même de quitter l'appareil et ne sont déverrouillées qu'une fois arrivées sur l'appareil de ton correspondant.

Ce mécanisme représente la protection ultime pour ta vie privée. Contrairement à un chiffrement classique où le serveur intermédiaire peut parfois « voir » les données, le chiffrement de bout en bout garantit que personne, pas même l'entreprise qui fournit l'application (WhatsApp, Signal, etc.), ne peut lire tes conversations.

Les avantages clés :

- **Confidentialité totale** : Tu es certain que seules les personnes autorisées accèdent à l'information.
- **Protection contre l'interception** : Même si un pirate intercepte les données durant leur transit sur le réseau, il ne trouvera qu'un texte chiffré totalement indéchiffrable.
- **Intégrité garantie** : Le système permet de s'assurer que le message n'a pas été modifié en chemin.

3 On appelle ça la « poignée de main » (ou *Handshake*)



Le chiffrement de bout en bout (lockself.com)

Fonctionnement (basé sur le chiffrement asymétrique) :

1. **Échange de clés** : Ton application et celle de ton correspondant s'échangent leurs clés publiques de manière transparente.
2. **Chiffrement au départ** : Quand tu envoies un message, ton appareil utilise la clé publique du destinataire pour coder le texte.
3. **Transit sécurisé** : Le message voyage sur Internet sous forme de « texte chiffré » illisible.
4. **Déchiffrement à l'arrivée** : Seul l'appareil du destinataire, possédant la clé privée correspondante, peut transformer le code en texte lisible.

Le chiffrement E2EE est aujourd'hui la norme pour les communications privées sur smartphone.

✔️ Règle d'or : Privilégie toujours les messageries utilisant le chiffrement de bout en bout pour tes conversations personnelles et sensibles.

6.4. Défis et limitations du chiffrement

6.4.1. Le défi de la gestion des clés

Plus tu utilises de services chiffrés, plus tu accumules de clés et mots de passe. Les gestionnaires de mots de passe (Bitwarden, 1Password, LastPass) deviennent essentiels pour :

- Générer des mots de passe uniques et forts
- Chiffrer et synchroniser tes identifiants
- Simplifier l'accès tout en maintenant la sécurité

6.4.2. L'équilibre performance-sécurité

Le chiffrement consomme des ressources :

- Processeur : Calculs cryptographiques intensifs
- Batterie : Impact sur l'autonomie des appareils mobiles
- Latence : Délai supplémentaire pour chiffrer/déchiffrer

Les constructeurs intègrent désormais des puces cryptographiques dédiées (TPM, Secure Enclave) pour accélérer ces opérations.

6.4.3. La menace quantique

Les ordinateurs quantiques, encore expérimentaux, pourraient casser RSA et ECC en quelques heures au lieu de millénaires. La communauté cryptographique développe de nouveaux algorithmes "post-quantiques" résistants à cette menace future.

6.5. Règles d'or du chiffrement

1. Vérifie toujours HTTPS avant de saisir des informations sensibles
2. Active le chiffrement sur tous tes appareils (smartphone, ordinateur, tablette)
3. Utilise des messageries avec chiffrement de bout en bout pour les conversations privées
4. Méfie-toi des Wi-Fi publics : utilise un VPN quand c'est possible

6.6. Outils recommandés

- Gestionnaire de mots de passe : Bitwarden (gratuit et open source)
- Messagerie sécurisée : Signal pour les conversations sensibles
- Navigation : Assure-toi que HTTPS est activé

6.7. Activités pratiques

6.7.1. Vérifier le chiffrement d'un site web

Exercice pratique : Analyser la sécurité d'un site web

1. Visite le site de ton établissement scolaire
2. Clique sur le cadenas dans la barre d'adresse
3. Examine le certificat : qui l'a émis ? quand expire-t-il ?

4. Compare avec un site non sécurisé (de plus en plus rares)

6.7.2. **Comparatif des messageries**

Prends connaissance de l'article suivant :
https://www.kaspersky.fr/resource-center/preemptive-safety/messaging-app-security

Ensuite, complète le tableau suivant :

Messagerie	*Chiffrement de bout en bout ?*	*Code source ouvert ?*	*Messages autodestructibles ?*	*Stockage local ?*	*Utilisation des données ?*
Telegram					
Signal					
WhatsApp					
iMessage					

Quel est le meilleur service de messagerie en matière de confidentialité ?

6.7.3. **Vulnérabilité des wifi publics**

Se connecter à un réseau wifi ouvert inconnu dans un espace public est une erreur de sécurité informatique notoire.

Explique pourquoi en illustrant tes propos par une démonstration du logiciel Wireshark.

Explique également, via le flux d'information généré, comment un hacker pourrait obtenir des informations sur une des cibles situées dans le réseau.

Pour cela :

1. Rends-toi sur un site Wordpress qui n'utilise pas HTTPS
2. Accède à la page « WP-ADMIN »
3. Rempli le formulaire avec un nom d'utilisateur et un mot de passe
4. Retrouve ces informations sensibles à l'aide du logiciel Wireshark

6.7.4. **Cracker un mot de passe hashé**

Lorsqu'une personne veut retrouver un mot de passe caché (par exemple sous forme de

hash), elle peut utiliser une technique appelée **attaque par dictionnaire**. Voici comment ça fonctionne :

1. On prépare un grand fichier qui contient des mots de passe courants ou probables (par exemple : "azerty", "bonjour123", "motdepasse"...).
2. Pour chaque mot de passe de cette liste, on le transforme à l'aide du même algorithme (hash) que celui utilisé pour protéger le mot de passe à retrouver.
3. À chaque fois qu'un hash généré correspond exactement au hash à retrouver, on a découvert le mot de passe original.

Attention : cette méthode marche surtout si le mot de passe recherché est simple ou fréquent. Si le mot de passe est long, aléatoire ou très rare, on a peu de chances de tomber dessus.

crackstation.net est un site web qui fait tout ce travail automatiquement et à grande échelle. Il possède déjà une gigantesque base de données avec des millions de mots de passe et leurs hashs correspondants, calculés à l'avance. Au lieu de lancer manuellement une attaque par dictionnaire, l'utilisateur peut simplement fournir un hash à CrackStation, qui va instantanément regarder dans sa base si le hash correspond à un mot de passe connu :

- Si le hash existe dans la base, CrackStation affiche le mot de passe original.
- Si le hash ne correspond à rien, c'est probablement que le mot de passe était trop complexe ou pas dans la base.

En résumé, CrackStation simplifie et accélère énormément la méthode classique de recherche, en utilisant la puissance d'un gigantesque dictionnaire déjà prêt, et automatisant la comparaison : il devient alors très facile de retrouver des mots de passe... du moins s'ils sont faibles ou courants.

Voici une liste de mots de passe chiffrés. Peux-tu les déchiffrer en utilisant l'outil CrackStation ?

Hash	Mot de passe déchiffré
5f4dcc3b5aa765d61d8327deb882cf99	
e99a18c428cb38d5f260853678922e03	
7b0a7e4d05c63ae18e58c6c21f699485	
0d107d09f5bbe40cade3de5c71e9e9b7	
67d23692bf970da6d0d2d7bd5840001f	

Pourquoi faut-il choisir un mot de passe long et original ?

7. L'intégrité des données

Un *système d'intégrité* désigne l'ensemble des dispositifs, processus et règles permettant de garantir que les données ou le fonctionnement d'un système informatique ne sont pas altérés, modifiés ou détruits de manière non autorisée, que ce soit de façon accidentelle ou malveillante.

Garantir l'intégrité revient à **prouver qu'une donnée est restée exactement identique entre le moment où elle a été créée et celui où on la consulte** .

C'est l'assurance-vie de tes fichiers : un devoir rendu, un mot de passe haché ou une mise à jour système doivent demeurer intouchés, sinon la confiance disparaît. On distingue deux grands volets.

7.1. Intégrité physique vs. logique

Dimension	Objectif	Exemples de menaces	Contremesures
Physique	Garantir que les bits stockés = bits lus	Secteur disque défectueux, panne électrique, rayonnement	RAID, SSD ECC, onduleur, systèmes de fichiers avec checksum (ZFS, Btrfs)
Logique	Garantir que les données « ont du sens »	Mauvaise saisie, corruption logicielle, malware	Hash, signature numérique, contraintes de base SQL (clé primaire, clé étrangère)

7.2. Les empreintes (hash)

Un hash (ou empreinte numérique, fonction de hachage) est une courte chaîne de caractères générée par un algorithme à partir du contenu d'un fichier ou d'un texte. Cette empreinte a plusieurs propriétés essentielles :

- **Identité unique** : chaque fichier, même très volumineux, est résumé par un hash de taille fixe (ex : 64 caractères pour SHA-256).
- **Modification détectable** : le moindre changement dans le fichier (même un seul caractère) produit un hash complètement différent.
- **Vérification d'intégrité** : comparer le hash d'un fichier téléchargé avec celui fourni par la source permet de s'assurer qu'il n'a pas été modifié ou corrompu pendant le transfert.
- **Sécurité** : les fonctions de hachage sont conçues pour être irréversibles : on ne peut

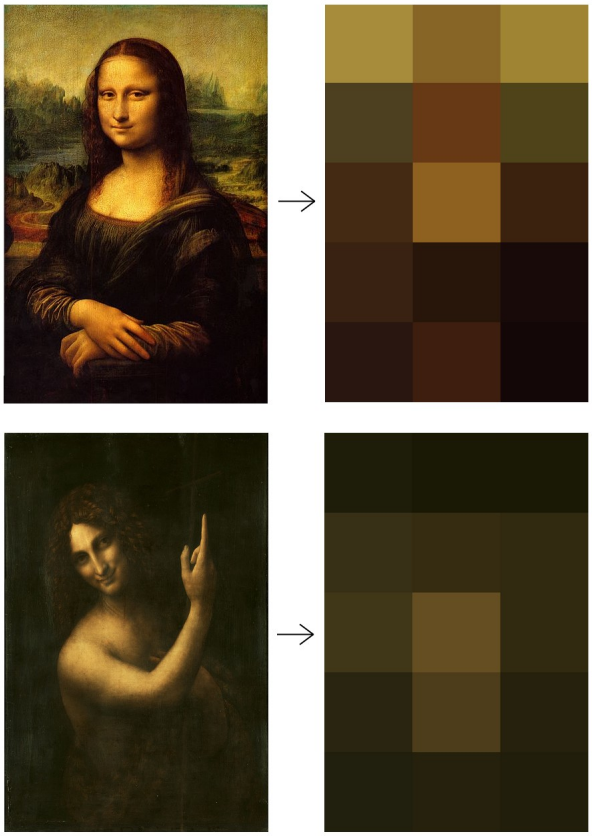
pas retrouver le contenu d'origine à partir du hash.

7.2.1. **Exemple pratique**[4]

Imagine que tu possèdes deux images de tableaux célèbres en ultra-haute définition (plusieurs gigaoctets chacune). Comment un ordinateur pourrait les distinguer rapidement sans devoir comparer chaque fichier pixel par pixel, ce qui prendrait énormément de temps pour lui ?

Pour résoudre ce problème, un ordinateur utilise le hash : il converti une image complexe en une empreinte de très basse résolution, composée de seulement quelques gros carrés de couleur.

- empreinte ultra-légère : contrairement au fichier original qui est massif, cette empreinte est beaucoup plus légère en mémoire.
- distinction immédiate : bien que l'on perde une grande partie des détails (l'information), cette signature visuelle reste suffisante pour distinguer rapidement deux images.



Ici, l'ordinateur distingue rapidement La Joconde (tableau du haut) de Saint Jean-Baptiste (tableau du bas).

4 Exemple tiré de https://fr.wikipedia.org/wiki/Fonction_de_hachage

7.2.2. Calculer le hash d'un fichier sur Windows

1. Ouvre Powershell
2. Tape la commande suivante pour calculer le hash SHA-256 d'un fichier

```
Get-FileHash -Algorithm SHA256 -Path "C:\chemin\vers\tonfichier.pdf"
```

3. Compare la valeur affichée avec celle fournie par la source officielle (site web, professeur, etc.).

7.2.3. Calculer le hash d'un fichier sur MacOS

1. Ouvre le Terminal
2. Tape la commande suivante pour calculer le hash SHA-256 d'un fichier

```
shasum -a 256 /chemin/vers/tonfichier.pdf
```

3. Compare la valeur affichée avec celle fournie par la source officielle (site web, professeur, etc.).

7.2.4. Calculer le hash d'un fichier sur Linux

1. Ouvre le Terminal
2. Tape la commande suivante pour calculer le hash SHA-256 d'un fichier

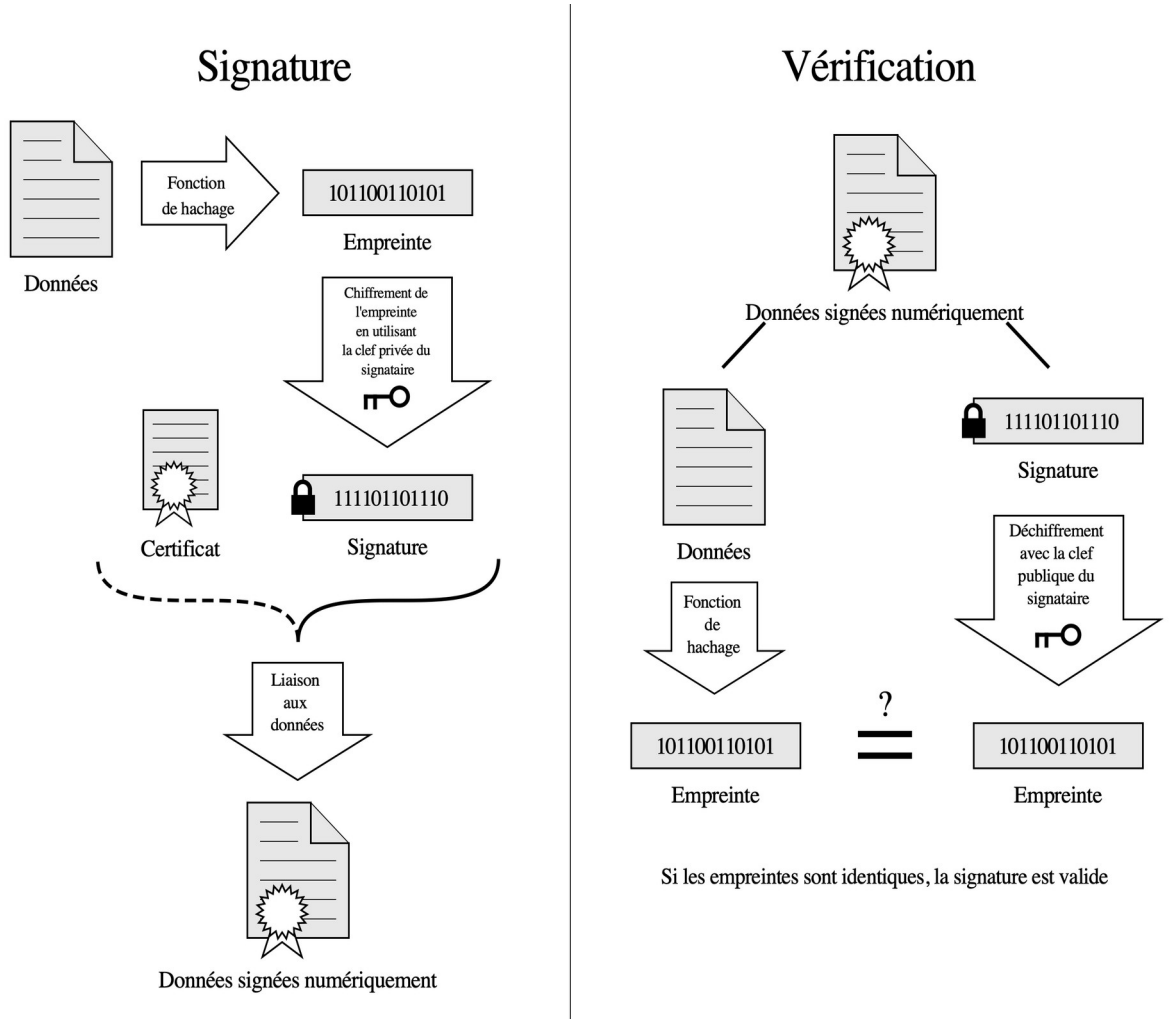
```
sha256sum /chemin/vers/tonfichier.pdf
```

3. Compare la valeur affichée avec celle fournie par la source officielle (site web, professeur, etc.).

7.3. **Signature numérique**

Une **signature** est un code cryptographique ajouté à un fichier ou un message pour prouver son authenticité et son intégrité.

Elle est créée à l'aide de la clé privée de l'auteur : si quelqu'un modifie le fichier après sa signature, la signature devient invalide. Toute personne possédant la clé publique du signataire peut alors vérifier que le fichier n'a pas été altéré et qu'il provient bien de la source annoncée. C'est un moyen fiable de garantir qu'un document téléchargé ou reçu n'a pas été falsifié et qu'il est bien signé par la bonne personne ou organisation.



Fonctionnement de la signature numérique (wikipedia)

Par exemple, pour un téléchargement (ISO Linux, document officiel), le site fournit souvent :

1. le hash du fichier téléchargé (`SHA256SUMS`);
2. une signature GPG (`SHA256SUMS.gpg`).

La vérification se fait en trois étapes :

1. Importer la clé publique du fournisseur[5]

```
gpg --keyserver hkps://keys.openpgp.org --recv-keys <ID>
```

Remplace `<ID>` par l'identifiant de la clé publique du fournisseur (exemple : `DA87E80D6294BE9B`).

Cette commande fonctionne de la même façon sur Windows, Linux et macOS (après installation de GnuPG).

2. Vérifier la signature du fichier de hash

```
gpg --verify SHA256SUMS.gpg SHA256SUMS
```

Cette commande fonctionne de la même façon sur Windows, Linux et macOS (après installation de GnuPG).

3. Contrôler le fichier téléchargé

```
# Linux
sha256sum -c SHA256SUMS | grep OK

# MacOS
shasum -a 256 -c SHA256SUMS | grep OK

# Windows (Powershell)
Get-FileHash -Algorithm SHA256 -Path .\nomdufichier.iso
```

Si les trois étapes passent, tu es certain : l'éditeur est authentique, et le fichier n'a pas bougé.

7.4. Vérification d'intégrité en base de données

Dans un SGBD relationnel, l'intégrité s'appuie sur quatre contraintes :

1. Intégrité d'entité : clé primaire non nulle.

```
CREATE TABLE eleves (
    id INT PRIMARY KEY,
    ...
);
```

2. Intégrité référentielle : clés étrangères valides (ex. chaque devoir est toujours lié à un élève existant).

```
CREATE TABLE devoirs (
    ...
    eleve_id INT,
    FOREIGN KEY (eleve_id) REFERENCES eleves(id)
```

5 L'outil « GnuPG » est nécessaire : https://www.gnupg.org/download/index.html

```
);
```

3. Intégrité de domaine : chaque champ respecte son type et sa plage autorisée (ex. limite le texte à 100 caractères).

```sql
CREATE TABLE devoirs (
    ...
     titre VARCHAR(100),
    ...
);
```

4. Intégrité personnalisée : règles métier (ex. note entre 0 et 20).

```sql
CREATE TABLE evaluations (
    ...
    note INT CHECK (note >= 0 AND note <= 20),
    ...
);
```

7.5. Activités pratiques

7.5.1. Vérifier l'intégrité d'un devoir ou d'un document personnel

1. Prends un document texte ou PDF (par exemple, un devoir à rendre).
2. Calcule son hash avec l'outil de ton choix :
   - Windows : clic droit > Propriétés > onglet Hachages (avec HashTab ou HashTools).
   - Linux/macOS : `shasum -a 256 fichier.pdf`.
3. Note la valeur obtenue.
4. Modifie le fichier (ajoute un espace, change une lettre), recalcule le hash

Quelles sont tes constatation ?

7.5.2. Comparer deux versions d'un même fichier

1. Crée un fichier texte `exemple.txt` contenant « Bonjour ».
2. Fais-en une copie, nommée `exemple2.txt`, et ajoute un point ou un espace.
3. Calcule le hash des deux fichiers :
   - **Windows** : avec HashTab, HashTools, PowerShell (`Get-FileHash`).
   - **Linux/macOS** : `sha256sum exemple.txt exemple2.txt`.

4. Compare les valeurs.

Quelles sont tes constatation ?

7.5.3. **Vérification de l'ISO Ubuntu**

Suivre le tutoriel :
https://doc.ubuntu-fr.org/tutoriel/comment_verifier_l_integrite_de_son_image_cd

7.5.4. **Cryptris**

https://cryptris.nl

7.6. Bonnes pratiques

- ✔ **Toujours** vérifier les hash des logiciels téléchargés.
- ✔ **Utiliser SHA-256 ou mieux** ; éviter MD5/SHA-1 obsolètes.
- ✔ **Activer les mises à jour automatiques** : elles incluent souvent une vérification de signature.

7.7. Enjeux futurs

Menace quantique : certains algorithmes de hash résisteront, d'autres non – la recherche post-quantique progresse.

> *En appliquant ces mécanismes (hash, signature, contraintes SQL, etc.) tu transformes l'intégrité en réflexe : chaque fichier, chaque note, chaque ligne de code est protégée contre l'altération volontaire ou accidentelle.*

8. La sauvegarde des données

Un *système de sauvegarde* est un ensemble de moyens (logiciels, matériels, procédures) permettant de créer, stocker et gérer des copies de données provenant d'un ordinateur, d'un serveur ou d'un réseau, dans le but de les protéger contre la perte, la corruption ou la suppression accidentelle.

Il consiste à dupliquer les fichiers ou bases de données vers un emplacement sécurisé, distinct de l'original (disque dur externe, cloud, serveur distant, etc.), afin de pouvoir restaurer les informations en cas d'incident (panne, attaque, erreur humaine, sinistre).
Un bon système de sauvegarde permet ainsi de garantir la continuité d'activité, la sécurité et la disponibilité des données importantes.

8.1. Scénarios courants de perte de données

- **Suppression accidentelle** : tu effaces par erreur ton dossier de TPE une semaine avant la soutenance
- **Panne matérielle** : le disque dur de ton ordinateur portable lâche pendant les révisions du bac
- **Vol ou casse** : ton sac avec l'ordinateur disparaît ou tombe
- **Virus et ransomwares** : un malware chiffre tous tes fichiers et exige une rançon
- **Erreur de manipulation** : tu écrases accidentellement la bonne version d'un devoir avec une version corrompue

8.2. Les trois types de sauvegarde

8.2.1. Sauvegarde complète

La sauvegarde complète copie l'intégralité du jeu de données qu'elles aient été modifiées ou non. C'est comme faire une photocopie intégrale de tous tes dossiers.

Avantage	Inconvénient
Restauration simple : un seul fichier à récupérer contient tout	**Temps de traitement** : sauvegarder de grandes quantités prend du temps
Gestion claire : chaque sauvegarde est une copie complète	**Coûts de stockage élevés** : chaque sauvegarde prend beaucoup d'espace
Contrôle de version facile : revenir à une date spécifique est simple	**Pas idéal pour de gros ensembles de données** si tu sauvegardes quotidiennement

8.2.2. Sauvegarde incrémentielle

Une sauvegarde incrémentielle ne copie que les données modifiées depuis la dernière

sauvegarde. Par exemple, si tu as fait une sauvegarde complète dimanche, la sauvegarde incrémentielle du lundi ne copiera que les fichiers modifiés depuis dimanche.

Fonctionnement pratique :

1. Dimanche : sauvegarde complète (10 Go)
2. Lundi : sauvegarde incrémentielle (200 Mo de modifications)
3. Mardi : sauvegarde incrémentielle (150 Mo de nouvelles modifications)

Avantage	Inconvénient
Rapidité : seuls les changements sont sauvegardés **Économie d'espace** : utilisation efficace du stockage **Fréquence élevée** : peut être réalisée plusieurs fois par jour	**Restauration complexe** : tu as besoin de la sauvegarde complète ET de toutes les sauvegardes incrémentales **Vulnérabilité** : si un fichier incrémental est corrompu, la récupération peut échouer

Les sauvegardes dans le Cloud (OneDrive, iCloud, Google Drive, etc.) sont principalement des sauvegardes incrémentielles après une première sauvegarde complète. Ce fonctionnement est optimal pour la synchronisation rapide et la restauration efficace de tes données en cas de besoin.

Ces services utilisent une approche hybride et optimisée. Même s'ils fonctionnent en mode incrémentiel pour économiser la bande passante et l'espace, ils maintiennent en permanence une image complète et cohérente de tes fichiers sur leurs serveurs. Cela signifie que :

- ✔ Tu peux restaurer tout ou partie de tes fichiers à n'importe quel moment, sans avoir à gérer manuellement une chaîne de sauvegardes.
- ✔ Le service gère automatiquement l'intégrité des données et la reconstruction de l'état final, même si plusieurs sauvegardes incrémentielles ont eu lieu.

Les inconvénients classiques des sauvegardes incrémentielles (restauration complexe, dépendance à chaque incrément) sont masqués pour l'utilisateur sur OneDrive, iCloud, Google Drive, etc., car ces plateformes reconstruisent automatiquement la version complète à restaurer. L'utilisateur bénéficie donc de la rapidité de l'incrémentiel sans la complexité de la restauration, grâce à l'infrastructure du fournisseur cloud qui gère tout en arrière-plan.

8.2.3. **Sauvegarde différentielle**

Une sauvegarde différentielle copie tous les changements depuis la dernière sauvegarde complète. Contrairement à l'incrémentielle, elle inclut TOUS les changements depuis le point de référence complet.

Fonctionnement pratique :

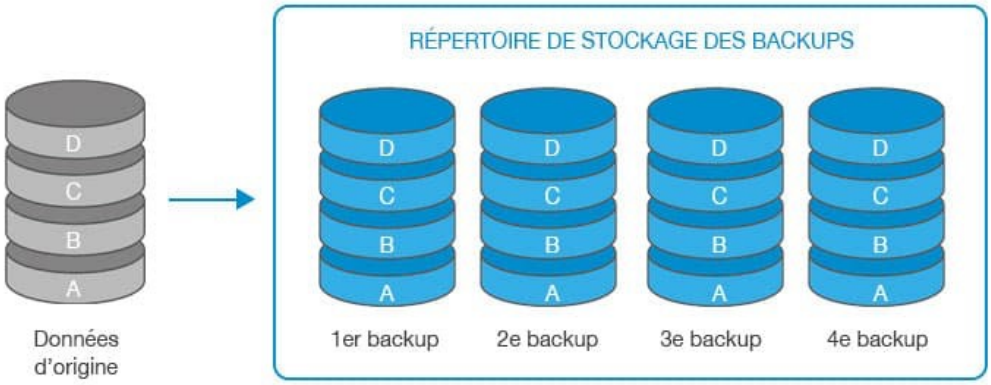
- Dimanche : sauvegarde complète (10 Go – point de référence)
- Lundi : sauvegarde différentielle (200 Mo depuis dimanche)
- Mardi : sauvegarde différentielle (350 Mo depuis dimanche - inclut lundi + mardi)

Avantage	Inconvénient
Restauration simplifiée : seulement la sauvegarde complète + la dernière différentielle **Plus petite** que les sauvegardes complètes mais plus grande que les incrémentales	**Taille croissante** : chaque sauvegarde différentielle devient plus volumineuse **Plus lente** que les sauvegardes incrémentales

DIFFÉRENCES BACKUP COMPLET / BACKUP INCRÉMENTIEL

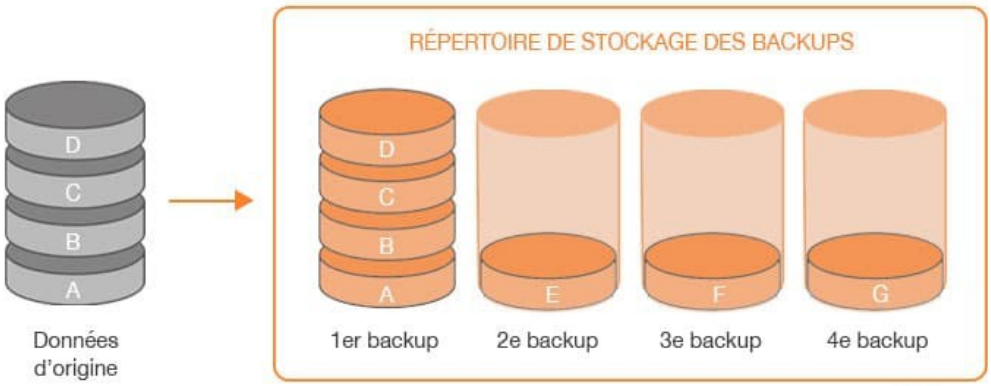
BACKUP COMPLET

À chaque sauvegarde, les données sont copiées dans leur intégralité.



BACKUP INCRÉMENTIEL

Une première sauvegarde complète est réalisée. Puis, chaque backup enregistre les modifications et ajouts depuis le backup précédent.

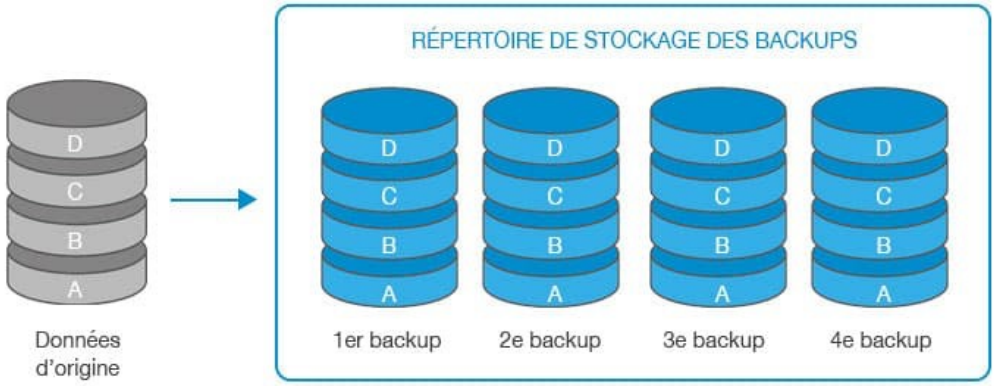


savbox
SOLUTIONS DE SAUVEGARDE

DIFFÉRENCES BACKUP COMPLET / BACKUP DIFFÉRENTIEL

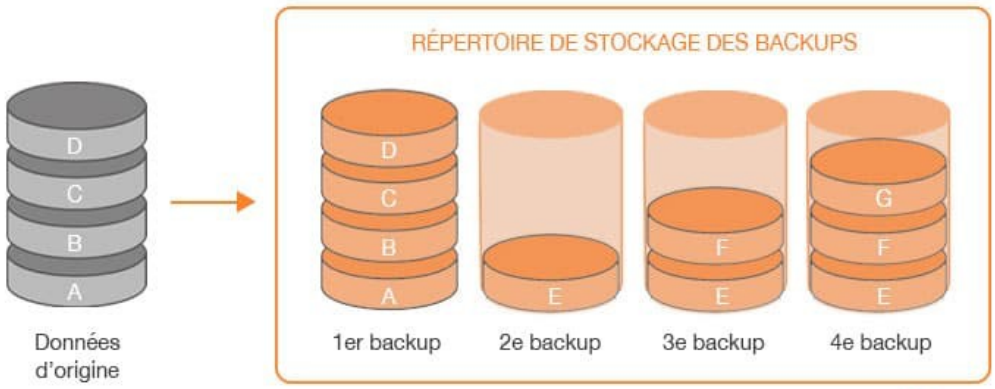
BACKUP COMPLET

Les données sont copiées entièrement à chaque sauvegarde



BACKUP DIFFÉRENTIEL

Les données sont d'abord copiées dans leur intégralité. Puis, chaque sauvegarde enregistre les modifications et ajouts depuis le dernier backup complet.



savbox
SOLUTIONS DE SAUVEGARDE

8.3. La règle 3-2-1

La règle de sauvegarde 3-2-1 stipule que vous devez avoir au moins trois copies de vos données; deux des sauvegardes doivent être stockées sur des types de supports différents, et au moins une sauvegarde doit être stockée hors site.

Par exemple :

- Une première sauvegarde sur ton ordinateur personnel
- Un deuxième sauvegarde sur un disque dur externe
- Une troisième sauvegarde dans le Cloud

Les avantages de cette approches sont nombreux :

- ✔ **Diversification des emplacements** : évite qu'un incident local détruise toutes tes sauvegardes
- ✔ **Indépendance** : tu ne dépends pas d'une seule sauvegarde de données
- ✔ **Protection renforcée** : augmente considérablement la protection des données

8.4. Solutions de sauvegarde

8.4.1. Sauvegarde automatique de Windows

L'historique des fichiers de Windows constitue une solution simple et gratuite intégrée au système. Cette fonctionnalité sauvegarde automatiquement tes documents, photos, musique et autres fichiers critiques.

Activation étape par étape :

1. Connecte un disque externe (disque dur USB, grande clé USB)
2. Ouvre les Paramètres Windows > Mise à jour et sécurité > Sauvegarde
3. Clique sur le + à côté de "Ajouter un lecteur"
4. Sélectionne ton unité externe
5. Configure la fréquence : par défaut, sauvegarde toutes les heures

Personnalisation avancée :

- Fréquence : de toutes les 10 minutes à tous les jours
- Conservation : de 1 mois à "Pour toujours"
- Dossiers inclus : Documents, Bureau, Images, Vidéos par défaut
- Exclusions : possibilité d'exclure certains types de fichiers

8.4.2. Solutions Cloud

Les solutions sont nombreuses : OneDrive, Google Drive, pCloud, iCloud, etc.

Avantages spécifiques :

- Collaboration en temps réel sur documents avec Google Docs, Sheets
- Synchronisation automatique sur tous tes appareils
- Historique des versions : récupère les versions précédentes de tes documents
- Partage sécurisé avec tes camarades et professeurs

La plupart des services proposent des solutions gratuites limitées à quelques gigaoctets.

8.5. **Protection spécifique contre les ransomwares**

L'augmentation massive des cyberattaques, en particulier des attaques par ransomware (logiciels malveillants qui prennent en otage tes fichiers en les chiffrant et exigent ensuite une rançon pour rendre l'accès aux données), nécessite d'améliorer les principes de base de la stratégie de sauvegarde 3-2-1.

> *(Le terme "ransomware" sera expliqué de façon détaillée dans la section suivante, mais retiens déjà qu'il s'agit d'un type de cyberattaque de plus en plus fréquent qui cible les particuliers, les entreprises et même les établissements scolaires.)*

Évolution moderne de la règle classique :

- **3** copies de données
- **2** supports différents
- **1** sauvegarde hors site
- **1** sauvegarde hors ligne (déconnectée du réseau)
- **0** erreur dans les sauvegardes

8.6. **Audit de sécurité personnel**

Objectif : Évaluer la robustesse de ta stratégie de sauvegarde.

8.7. **Exercices**

8.7.1. **Entoure la bonne réponse**

Tu as effectué une sauvegarde complète (A) le dimanche, puis des sauvegardes **incrémentielles** chaque soir (B le lundi, C le mardi, D le mercredi). Le jeudi matin, ton disque dur tombe en panne. De quelle(s) sauvegarde(s) as-tu besoin exactement pour récupérer l'entièreté de tes données ?

- Uniquement A
- A et D
- A, B, C et D
- B, C et D
- A et C
- Uniquement D

Même question que la précédent mais avec des sauvegardes **différentielles**.

- Uniquement A
- A et D
- A, B, C et D
- B, C et D
- A et C
- Uniquement D

Tu as effectué une sauvegarde complète (A) le dimanche. Le lundi et le mardi soir, tu effectues ta sauvegarde **incrémentielle** (B et C). Le mercredi matin, ton disque dur tombe en panne et tu te rends compte que la sauvegarde B est perdue. Est-il possible de récupérer l'entièreté des données ?

- Oui car les données du lundi sont incluses dans la sauvegarde C
- Non car les données du lundi ne sont pas incluses dans la sauvegarde C
- Oui car dans une sauvegarde incrémentielle, chaque sauvegarde inclut toutes les modifications depuis la sauvegarde complète
- Non car les données du mardi ne sont pas incluses dans la sauvegarde C

Concernant la question précédente, quelle(s) donnée(s) peut-on tout de même récupérer ?

- Les données du dimanche et du lundi uniquement
- Les données du dimanche et du mardi uniquement
- Les données du lundi et du mardi uniquement
- L'entièreté des données du dimanche, lundi et mardi

Tu as effectué une sauvegarde complète (A) le dimanche. Le lundi et le mardi soir, tu effectues ta sauvegarde **différentielle** (B et C). Le mercredi matin, ton disque dur tombe en panne et tu te rends compte que la sauvegarde B est perdue. Est-il possible de récupérer l'entièreté des données ?

- Oui car les données du lundi sont incluses dans la sauvegarde C
- Non car les données du lundi ne sont pas incluses dans la sauvegarde C
- Non car les données du mardi ne sont pas incluses dans la sauvegarde C

Concernant la question précédente, quelle(s) donnée(s) peut-on tout de même récupérer ?

- Les données du dimanche et du lundi uniquement
- Les données du dimanche et du mardi uniquement
- Les données du lundi et du mardi uniquement
- L'entièreté des données du dimanche, lundi et mardi

9. Les logiciels malveillants

Les logiciels malveillants – ou *malwares* – sont des programmes développés pour infiltrer, endommager ou prendre le contrôle d'un système sans le consentement de l'utilisateur.

Les malwares menacent simultanément la confidentialité, l'intégrité et la disponibilité des données : vol d'informations, altération de fichiers, blocage complet d'un poste ou d'un réseau.

9.1. Panorama des grandes familles de malwares

Catégorie	Mode d'infection	Propagation	Objectif
Virus	Fichier ou exécutable contaminé	Action humaine (ouvrir un fichier)	Altération ou destruction de données
Ver (worm)	Exploitation d'une faille réseau	Automatique, sans hôte	Saturation réseau, altération ou destruction de données
Cheval de Troie (trojan)	Ingénierie sociale, logiciel « utile » piégé	Ne se réplique pas seul	Porte dérobée, vol d'identifiants
Rançongiciel (ransomware)	Pièce jointe, faille système	Automatique, sans hôte	Chiffrer les fichiers puis extorquer une rançon
Spyware / Keylogger	Logiciel, lien piégé	Discret, persistant	Espionnage, vol de mots de passe
Rootkit	Exploit avec privilèges élevés	Se cache dans le noyau ou le firmware	Masquage d'autres malwares, contrôle complet
Botnet	Infection par ver ou trojan	Commande et contrôle à distance	DDoS, spam, minage illicite

9.2. Fonctionnement détaillé

9.2.1. Le virus

Attache son code à un programme ou document hébergeur. Quand l'utilisateur exécute ce dernier, le virus se copie vers d'autres fichiers ou périphériques ; il reste dépendant de l'action humaine.

9.2.2. Le ver

Programme autonome qui exploite une faille (partage réseau, service ouvert) pour se dupliquer d'ordinateur en ordinateur sans intervention manuelle. Il consomme rapidement bande passante et ressources processeur, pouvant provoquer un déni de service.

> *Un exemple de ver bien connu est Stuxnet, un malware conçu par la NSA et la CIA, pour s'attaquer aux centrifugeuses iraniennes d'enrichissement d'uranium.Je t'invite à découvrir son histoire à travers la vidéo du vidéaste Micode en scannant le QR Code.*

9.2.3. **Le Cheval de Troie**

Se fait passer pour un logiciel légitime (jeu cracké, extension de navigateur, mise à jour factice) afin d'être installé. Une fois actif, il ouvre souvent une porte dérobée permettant un accès discret et durable à l'attaquant.

> *Une **porte dérobée** (ou backdoor en anglais) est un accès secret et caché, volontairement créé dans un logiciel, un système informatique ou un matériel, permettant à une personne (souvent malveillante) de contourner les mécanismes de sécurité standards, comme l'authentification. Cette porte donne ainsi un accès non autorisé au système, offrant la possibilité de le contrôler, d'espionner son utilisateur, de modifier ou de voler des données, souvent à l'insu de la victime.*

9.2.4. **Le rançongiciel**

Chiffre les fichiers ou bloque l'écran puis affiche une demande de paiement (souvent en cryptomonnaie) pour restituer la clé. Certaines variantes exfiltrent d'abord les données et menacent de les publier (double extorsion).

9.2.5. **Le Spyware / Keylogger**

Surveille l'activité : frappes clavier, historique de navigation, captures d'écran. Les informations sont transmises à l'attaquant, facilitant l'usurpation d'identité ou le chantage.

9.2.6. **Le Rootkit**

Package de hacks qui s'installe au plus près du noyau, modifie les appels système et cache sa présence ainsi que celle d'autres malwares. Sa détection nécessite souvent l'amorçage sur un support sain ou l'analyse hors ligne du disque.

> *Le **noyau** (ou kernel en anglais) est le cœur du système d'exploitation. C'est le programme fondamental qui fait le lien entre le matériel (processeurs, mémoire, disques, périphériques…) et les logiciels que tu utilises (navigateur, traitement de texte, jeux…).*

9.2.7. **Le Botnet**

Réseau de machines zombifiées contrôlées à distance. Les ordinateurs infectés peuvent lancer des attaques DDoS, relayer du spam ou miner des cryptomonnaies, généralement à l'insu de leur propriétaire.

> *Une attaque **DDoS** (Distributed Denial of Service, ou attaque par déni de service*

> *distribué) consiste à rendre un site web, un serveur ou un service en ligne indisponible en l'inondant simultanément de nombreuses requêtes malveillantes provenant de multiples ordinateurs ou appareils infectés à distance.*

9.3. Chaine d'infection typique

Un malware aboutit rarement sur un ordinateur « par magie ». Il suit presque toujours une chaîne d'événements qui commence par la tromperie de l'utilisateur et se termine, dans le pire des cas, par la prise de contrôle durable de la machine. Comprendre chacune des étapes permet d'installer les bons « pare-chocs » de sécurité au bon endroit.

9.3.1. Ingénierie sociale : la ruse avant la technique

Tout commence généralement par une étape d'ingénierie sociale. Ici, l'attaquant n'utilise pas encore de technologie complexe : **il joue sur la naïveté, la curiosité ou la peur** de l'utilisateur.

L'exemple le plus courant est le courriel de phishing, prenant la forme d'un message urgent ou officiel : "Votre compte sera désactivé", "Nouveau devoir à consulter", ou "Vous avez gagné un lot". À l'intérieur, un lien renvoie vers un faux site, ou une pièce jointe contient un document piégé. Il peut aussi s'agir d'un faux site de téléchargement, qui propose par exemple un jeu, une mise à jour factice ou un convertisseur de fichier, mais qui cache en réalité un programme malveillant.

Le but est simple : pousser la victime à cliquer ou ouvrir un fichier, déclenchant l'infection.

9.3.2. Exploitation : la faille qui laisse entrer le programme

Une fois que l'utilisateur a cliqué, ouvert ou lancé le fichier piégé, l'attaquant passe à l'étape d'exploitation. Celle-ci repose soit sur cette **action de l'utilisateur**, soit sur une **faille du système non corrigée**.

Par exemple, un document Word contenant une macro malveillante peut exécuter automatiquement du code dès que l'utilisateur clique sur "Activer le contenu". Autre scénario : un pirate profite d'une vulnérabilité logicielle connue (comme une faille dans Windows ou un service réseau mal configuré) pour injecter du code sans que l'utilisateur ne s'en aperçoive.

Ces failles sont souvent déjà corrigées dans les mises à jour, mais restent dangereuses sur les machines non à jour.

9.3.3. Installation : le malware prend ses quartiers

À cette étape, le programme malveillant est installé sur l'ordinateur. Parfois, cette étape est assurée par ce que l'on appelle un dropper : un petit programme de "pré-infection" dont le seul but est de télécharger le malware principal, de l'installer et parfois même de s'auto-effacer pour ne pas laisser de traces.

Le malware peut alors s'ajouter aux programmes qui se lancent au démarrage, modifier le registre (sous Windows), ou s'installer dans un emplacement discret du disque. L'utilisateur, lui, ne voit souvent rien du tout à ce stade – l'infection se fait en arrière-plan, sans alerte apparente.

9.3.4. **Action : le malware remplit sa mission**

Une fois installé, le malware déclenche son action principale, qu'on appelle aussi le *payload*. Cette action dépend du type de logiciel malveillant : s'il s'agit d'un ransomware, il chiffre les fichiers de la victime pour exiger une rançon. S'il s'agit d'un spyware ou d'un keylogger, il espionne l'utilisateur, enregistre ses frappes clavier ou envoie ses informations confidentielles (mots de passe, messages…) à l'attaquant. Le malware peut aussi créer une porte dérobée (backdoor), c'est-à-dire un accès secret laissant la possibilité au pirate de revenir plus tard et reprendre la main sur la machine, à distance.

9.3.5. **Propagation ou persistance : survivre et infecter les autres**

Lors de la dernière étape, le malware cherche soit à **se propager**, soit à **rester actif sur le système même après redémarrage**.

Certains logiciels, comme les vers (worms), vont automatiquement chercher à infecter d'autres ordinateurs sur le même réseau : on parle alors de **propagation**. C'est le cas de logiciels célèbres comme WannaCry, qui a touché des centaines de milliers d'ordinateurs en quelques heures.

D'autres malwares, au lieu de se propager, vont chercher à s'incruster profondément dans le système, notamment via un **rootkit**. Ce type de composant se greffe au système d'exploitation lui-même (parfois au niveau du noyau), rendant le malware quasi invisible et très difficile à supprimer, même après redémarrage, voire réinstallation.

9.4. **Signes d'une infection**

- Ralentissement inhabituel, ventilateur à plein régime sans raison.
- Pop-ups ou redirections web soudaines.
- Programmes inconnus qui se lancent au démarrage.
- Activité réseau alors que l'ordinateur est inactif.
- Fichiers chiffrés portant l'extension « .locked » ou « .crypt ».

9.5. **Outils et commandes de détection**

Système	Antimalware intégré	Ligne de commande utile
Windows 10/11	Microsoft Defender	Get-MpThreatDetection (PowerShell) pour lister les détections
Linux	ClamAV (open source)	sudo freshclam puis clamscan -r /home

Système	Antimalware intégré	Ligne de commande utile
macOS	XProtect + MRT intégrés	sudo /usr/libexec/diagnosticd -help pour les journaux de sécurité

Ajouter **Malwarebytes** (multi-plateforme) pour un scan à la demande.

9.6. Bonnes pratiques

- ✔ **Mettre à jour** le système et les applications dès qu'un correctif est disponible : la majorité des vers exploitent des failles déjà connues.
- ✔ **Limiter les privilèges** : compte administrateur uniquement pour l'administration, pas pour la navigation.
- ✔ **Désactiver l'exécution automatique** des macros et analyser les fichiers téléchargés.
- ✔ **Filtrer le courriel** : antispam, blocage des pièces jointes potentiellement dangereuses (.exe, .js).
- ✔ **Sauvegarder hors ligne** : seule garantie de récupération après un ransomware.
- ✔ **Former les utilisateurs** : repérer un lien suspect, vérifier l'adresse d'expéditeur.

9.7. Activités pratiques

9.7.1. Test du phishing (Safeonweb)

Rends-toi sur https://safeonweb.be/fr/quiz/test-du-phishing ou scanne le QR Code suivant :

Réalise le test pour évaluer tes connaissances sur le phishing !